CPE 334 INTRODUCTION TO SOFTWARE ENGINEERING IN THE AGE OF AI AGENTS — SEMESTER 1/2026

Lab 3. TokTickIT Users, Roles, IT Staff Ticketing, and Admin Screens

Sprint 3 Comprehensive Engineering Report & Implementation Verification

AUTHOR (ผู้จัดทำ)
Thitigant Surayothin (รหัสนักศึกษา: 67070505214)

GITHUB REPOSITORY
github.com/thitigant/toktickit
(@thitigant)

PEER REVIEW PARTNER
Aran edlek (รหัสนักศึกษา: 67070505230, @aranedlek)

SUBMISSION DATE / TARGET BRANCH
4 ตุลาคม 2026 | Branch: `main` (merged from `lab3-staging`)

Answer Part 1: Git Use with Engineering Workflow — 10 Points

1.1 Commit-History Evidence (Feature Branches & Staging Merges)

กระบวนการพัฒนาใน Lab 3 ยึดหลักการ **Branching Strategy** อย่างเคร่งครัด โดยเริ่มจากการเปิด Feature Branches แยกตาม User Story แต่ละหัวข้อ, ทำการพัฒนาและเขียน Automated Test Suite ให้ครอบคลุม, ส่ง Pull Request ให้คู่ตรวจทาน (Peer Reviewer) ทำการ Review & Approve จากนั้นจึง Merge เข้าสาขา `lab3-staging` เพื่อทดสอบ E2E Integration และท้ายที่สุดทำการ Merge Pull Request #35 เข้าสู่สาขา `main`

```
* a108c32 fix(tests): resolve test failures across lab-01, lab-03 client and server
*   2dc6478 Merge pull request #35 from thitigant/lab3-staging
|\
| *   8569faf chore: resolve merge conflicts with main branch
| |\
| |/
|/|
* |   9a5ead7 Merge pull request #22 from thitigant/feature/lab-03-spec
|\ \
| * | 2ed7a55 docs: add lab-03 specification, api-spec, ui-spec, and tests traceability m
| | *   bfb93f8 Merge pull request #33 from thitigant/feature/lab3-e2e-tests
| | |\
| | | * e7d92c6 test(e2e): add Playwright end-to-end test suite for Lab 3 (closes #27)
| | |/
| | * 0d5ef32 docs(lab3): add Lab 3 specifications, tests, ui-spec, api-spec, reviewer, a
| | *   c499ac0 Merge pull request #32 from thitigant/feature/admin-user-management
| | |\
| | | * 5c6a2bd feat(admin): implement Admin User Management (FR-12, FR-13) APIs and UI
| | |/
| | *   1f32cf0 Merge pull request #31 from thitigant/feature/tickets-auth-ui
| | |\
```

```
| | | * b16354c feat(lab3): Login UI, auth flow, ticket operations, comments, internal no
| | |/
| | *   e344225 Merge pull request #30 from thitigant/feature/it-staff-queue
| | |\
| | | * 34f6242 feat(queue): implement IT Staff ticket queue API, filtering UI, and tests
| | |/
| | * 1c9fa58 Merge pull request #29 from thitigant/feature/auth-foundation
| |/|
| | * 33e8404 feat(auth): user model migration, password hashing, and authentication API
| |/
* 8d0f74f chore: finalize lab-02 and prepare for lab-03
```

[พื้นที่ใส่ภาพหน้าจอ: Git Commit Graph / Network View]

แสดงสายการแตกและรวม Branch: feature/* → lab3-staging → main

1.2 Final GitHub Project / Kanban Board Evidence (All Issues in Done)

ทุกชิ้นงานถูกแตกออกเป็น GitHub Issues ล่วงหน้า และจัดการผ่าน Kanban Board: **TokTickIT Sprint 3** โดยทุก Issue ได้รับการ Implement, ทดสอบ และปิดสถานะเป็น **Done** ครบ 100%:

Issue	หัวข้อและรายละเอียด (Scope)	Assignee	PR ที่เกี่ยวข้อง	Status
#21	Sprint 3 Engineering Contract & Specification (Spec DD)	@thitigant	PR #22	Done
#23	Auth Foundation: User Migration, bcrypt, JWT Token, /api/auth	@thitigant	PR #29	Done
#3	IT Staff Ticket Queue API & Multi-Filter Zen Green UI	@thitigant	PR #30	Done
#4	Ticket Operations: Claim/Assign, Priority, Comments, Notes	@thitigant	PR #31	Done
#25	Administrator User Management API, UI & Safety Rules	@thitigant	PR #32	Done
#27	Playwright E2E Test Suite for Lab 3 Full Operational Flow	@thitigant	PR #33	Done
#28	Release Integration, Peer Review Verification, Final Docs	@thitigant	PR #35	Done

[พื้นที่ใส่ภาพหน้าจอ: GitHub Project / Kanban Board]

แสดงคอลัมน์ Done ที่มี Issue ทั้งหมดของ Sprint 3 ครบถ้วน

1.3 Rendered reviewer.md (Peer Review Record)

ผู้จัดทำ (Author): Thitigant Surayothin (67070505214) — GitHub: @thitigant
คู่ตรวจทาน (Peer Reviewer): Aran edlek (67070505230) — GitHub: @aranedlek

Pull Requests ที่ส่งให้คู่ตรวจทาน (Authored PRs):

PR #	Feature Branch	Target	Verdict	Reviewer Comment & Response
#29	`feature/auth-foundation`	`lab3-staging`	Approved	**Comment:** "User model migration & password hashing เรียบร้อยครับ" *Response:* "ขอบคุณครับ"
#30	`feature/it-staff-queue`	`lab3-staging`	Approved	**Comment:** "IT Staff Queue API และ UI ค้นหา/กรอง ทำงานได้ถูกต้องตามสเปก" *Response:* "ขอบคุณครับ"
#31	`feature/tickets-auth-ui`	`lab3-staging`	Approved	**Comment:** "Login UI และ Ticket Detail Ticket Assignment / Comments / Internal Notes ผ่านครับ" *Response:* "ขอบคุณครับ"
#32	`feature/admin-user-management`	`lab3-staging`	Approved	**Comment:** "Admin User Management API และ Zen Green UI สมบูรณ์ Safety Rules ครบถ้วน" *Response:* "ขอบคุณครับ"

Pull Request ที่ตรวจทานให้เพื่อน (Reviewed PRs):

PR ของเพื่อน	Branch	Verdict	Reviewer Comment ที่เราให้
Admin User Management & Auth Workflow	`feature/lab3-admin-user-management`	Approved	"Code architecture สะอาด มีการป้องกัน Safety Rules ครบถ้วนและผ่าน test suites ทั้งหมดครับ"

1.4 README.md และ .gitignore Evidence

- **README.md Updates:** ได้รับการปรับปรุงชื่อเป็น *"TokTickIT — IT Service Desk Portal (Lab 3)"*, เพิ่มเนื้อหาฟีเจอร์ใหม่ **"What's New in Lab 3"**, ตาราง Default Login Credentials (User, Email, Password, Role, Initial Status), และคำสั่งสำหรับรัน E2E Test Suite เฉพาะของ Lab 3
- **.gitignore:** กรองไฟล์แปลกปลอมอย่างถูกต้อง เช่น `node_modules/`, `.env`, `dist/`, `*.log`, `test-results/` และ `playwright-report/`

1.5 โครงสร้างไฟล์ใน Repository (Directory Tree)

```
toktickit/
├── .gitignore
├── README.md
├── package.json
├── playwright.config.ts
├── docs/
│   ├── lab-02/
│   └── lab-03/
│       ├── specification.md
│       ├── tests.md
│       ├── ui-spec.md
│       ├── api-spec.md
│       ├── reviewer.md
```

```
│       ├── ai-use.md
│       ├── Lab_03_Report.md
│       └── Lab_03_Report.pdf
├── client/
│   ├── src/
│   │   ├── components/
│   │   │   ├── Login.tsx
│   │   │   ├── ChangePasswordModal.tsx
│   │   │   ├── StaffTicketQueue.tsx
│   │   │   ├── StaffTicketDetail.tsx
│   │   │   ├── UserManagement.tsx
│   │   │   └── AppHeader.tsx
│   │   ├── context/AuthContext.tsx
│   │   └── App.tsx
├── server/
│   ├── prisma/
│   │   ├── schema.prisma
│   │   └── seed.ts
│   ├── src/
│   │   ├── controllers/
│   │   │   ├── auth.controller.ts
│   │   │   ├── tickets.controller.ts
│   │   │   └── admin.controller.ts
│   │   ├── middleware/
│   │   │   └── auth.middleware.ts
│   │   └── routes/
│   └── tests/
│       ├── lab-02/
│       └── lab-03/
│           ├── auth.api.test.ts
│           ├── staff-queue.api.test.ts
│           ├── tickets-operations.api.test.ts
│           └── admin-user-management.api.test.ts
└── e2e/
    └── lab-03/
        └── staff-ticket-flow.spec.ts
```

Answer Part 2: Spec DD (Specification-Driven Development) 5 Points

ลิงก์ไฟล์เอกสารสเปกหลัก: `docs/lab-03/specification.md`
หลักฐานการมีอยู่ของสเปกล่วงหน้า: PR #22 (Commit `2ed7a55`) ถูกรวมเข้ามาก่อนการเปิด Feature Branches (#29, #30, #31, #32) เพื่อใช้เป็นสัญญาทางวิศวกรรม (Engineering Contract) ก่อนเริ่มลงมือเขียนโค้ด

2.1 Functional Requirements (FR-01 ถึง FR-13)

ID	ข้อกำหนดเชิงหน้าที่ (Functional Requirement Description)
FR-01	ระบบต้องยืนยันตัวตนผู้ใช้ผ่าน Email และ Password พร้อมคืนค่า JWT Bearer Token และข้อมูลโปรไฟล์
FR-02	ระบบต้องบังคับเปลี่ยนรหัสผ่านเมื่อเข้าสู่ระบบครั้งแรก (First-Login) หากบัญชีมีธง `mustChangePassword: true`
FR-03	ระบบต้องควบคุมสิทธิ์การเข้าถึงหน้าจอและ API ตาม Role ของผู้ใช้ (Requester, IT Staff, Administrator)
FR-04	Requester ต้องสามารถดูและจัดการเฉพาะตั๋วและไฟล์แนบที่ตนเองเป็นเจ้าของเท่านั้น
FR-05	IT Staff และ Admin ต้องมีหน้าจอ IT Ticket Queue เพื่อค้นหา, กรอง และแบ่งหน้า (Pagination)
FR-06	IT Staff และ Admin สามารถเคลมตั๋วเป็นของตนเอง (Self-claim) หรือมอบหมายงานให้ทีม IT Staff ได้
FR-07	IT Staff และ Admin สามารถปรับระดับความสำคัญของตั๋ว (IT Priority) ได้อย่างอิสระ
FR-08	IT Staff และ Admin สามารถปรับเปลี่ยนสถานะตั๋วตาม State Transition Workflow Matrix ที่กำหนด
FR-09	ผู้ใช้ทุกบทบาทสามารถอ่านและเขียนข้อความสนทนาสาธารณะ (Public Comments) บนตั๋วได้
FR-10	เฉพาะ IT Staff และ Admin เท่านั้นที่สามารถอ่านและเขียนบันทึกภายในเฉพาะทีม (Internal Notes) ได้
FR-11	Requester สามารถส่งสัญญาณ "Problem Appears Resolved" เพื่อแจ้งให้ IT Staff ทราบได้
FR-12	Administrator สามารถดูรายชื่อผู้ใช้ ค้นหา กรอง สร้างผู้ใช้ใหม่ และแก้ไขข้อมูลพื้นฐานผู้ใช้ได้
FR-13	Administrator สามารถรีเซ็ตรหัสผ่านชั่วคราวให้ผู้ใช้ และระบบจะตั้งค่าบังคับเปลี่ยนรหัสผ่านในการเข้าใช้งานถัดไป

2.2 Mandatory Business Rules (BR-01 ถึง BR-10)

ID	กฎทางธุรกิจ (Business Rule Description)
BR-01	เฉพาะบัญชีที่เปิดใช้งาน (`isActive = true`) และข้อมูลยืนยันตัวตนถูกต้องเท่านั้นที่สามารถเข้าสู่ระบบได้
BR-02	ผู้ใช้ที่มีธง `mustChangePassword = true` จะถูกระงับไม่ให้เข้าหน้าจอปกติจนกว่าจะเปลี่ยนรหัสผ่านใหม่สำเร็จ
BR-03	ตัวตนผู้ใช้ที่ผ่านการยืนยันจาก JWT Token เท่านั้นที่ใช้ระบุความเป็นเจ้าของตั๋ว (ไม่พึ่งพา client requesterId)
BR-04	Public Comments มองเห็นได้โดยทุก Role แต่ Internal Notes ถูกสงวนเฉพาะ IT Staff และ Admin เท่านั้น
BR-05	Requester ไม่สามารถปรับเปลี่ยนสถานะเป็น RESOLVED หรือ CLOSED ได้โดยตรง ต้องผ่านการดำเนินการของ IT Staff

ID	กฎทางธุรกิจ (Business Rule Description)
BR-06	รหัสผ่านใหม่ต้องมีความยาวอย่างน้อย 8 อักขระ ประกอบด้วยพิมพ์ใหญ่, พิมพ์เล็ก, ตัวเลข, และอักขระพิเศษ
BR-07	ห้ามมี Email ซ้ำกันในระบบอย่างเด็ดขาดทั้งตอนสร้างผู้ใช้และตอนแก้ไขข้อมูล
BR-08	**Safety Rule:** ห้าม Administrator ปิดการใช้งาน (Deactivate) บัญชีของตนเองที่กำลังล็อกอินอยู่
BR-09	**Safety Rule:** ห้ามลดสิทธิ์หรือปิดการใช้งานบัญชี Administrator ที่ Active อยู่เป็นคนสุดท้ายของระบบ
BR-10	การเปลี่ยนสถานะตั๋วต้องเป็นไปตาม State Matrix: NEW → OPEN / IN_PROGRESS → RESOLVED → CLOSED

2.3 Authorization Matrix

Endpoint / ฟังก์ชันการทำงาน	Requester	IT Staff	Administrator
`POST /api/auth/login` & `logout`	✅ Permitted	✅ Permitted	✅ Permitted
`GET /api/tickets` (My Tickets)	✅ Own Only	✅ All	✅ All
`GET /api/staff/tickets` (IT Queue)	❌ Forbidden (403)	✅ Permitted	✅ Permitted
`PATCH /api/tickets/:id/assign`	❌ Forbidden (403)	✅ Permitted	✅ Permitted
`PATCH /api/tickets/:id/priority`	❌ Forbidden (403)	✅ Permitted	✅ Permitted
`PATCH /api/tickets/:id/status`	❌ Forbidden (403)	✅ Permitted	✅ Permitted
`POST /api/tickets/:id/comments`	✅ Own Tickets	✅ Permitted	✅ Permitted
`POST /api/tickets/:id/internal-notes`	❌ Forbidden (403)	✅ Permitted	✅ Permitted
`GET /api/admin/users`	❌ Forbidden (403)	❌ Forbidden (403)	✅ Permitted
`POST /api/admin/users`	❌ Forbidden (403)	❌ Forbidden (403)	✅ Permitted
`PATCH /api/admin/users/:id`	❌ Forbidden (403)	❌ Forbidden (403)	✅ Permitted
`POST /api/admin/users/:id/reset-password`	❌ Forbidden (403)	❌ Forbidden (403)	✅ Permitted

2.4 Acceptance Criteria (AC-01 ถึง AC-07)

- **AC-01:** Given ผู้ใช้ที่ Active และข้อมูลถูกต้อง เมื่อทำการ Login ระบบต้องออก JWT Bearer Token และส่ง Profile กลับมาอย่างถูกต้อง
- **AC-02:** Given บัญชีที่มีธง `mustChangePassword: true` เมื่อเข้าสู่ระบบ หน้าจอปกติจะถูกบล็อกและบังคับให้เปลี่ยนรหัสผ่านก่อนเท่านั้น
- **AC-03:** Given Requester เข้าสู่ระบบ เมื่อพยายามเรียก Endpoint ของ Staff หรือ Admin ระบบต้องตอบกลับด้วย HTTP 403 Forbidden
- **AC-04:** Given IT Staff อยู่ที่หน้าคิวงาน สามารถเคลมตั๋ว, เปลี่ยน IT Priority, และเปลี่ยนสถานะตาม Transition Matrix ได้สำเร็จ
- **AC-05:** Given ตั๋วที่มีบันทึกภายใน (Internal Notes) ผู้ใช้ Requester จะต้องมองไม่เห็นข้อมูลบันทึกภายในนี้ทั้งบน UI และ API
- **AC-06:** Given Administrator จัดการผู้ใช้ ระบบต้องตรวจสอบความซ้ำซ้อนของ Email และบล็อกการ Deactivate บัญชีตนเองหรือ Admin คนสุดท้าย
- **AC-07:** Given ตั๋วและไฟล์แนบเดิมจาก Lab 2 ข้อมูลทั้งหมดต้องยังคงอยู่ครบถ้วนและผูกโยงกับ User ID เจ้าของเดิมอย่างถูกต้อง

2.5 Migration Decisions & Product Definition of Done (DoD)

Data Migration: แปลงโมเดล Development Requester เดิมให้เป็น `User` Model เต็มรูปแบบใน Prisma โดยเชื่อมต่อกับตาราง `Ticket` ผ่าน Foreign Key `requesterId` และเพิ่ม Foreign Key `ownerId` สำหรับ IT Staff โดยรหัสผ่านถูกเข้ารหัสด้วย `bcryptjs` (Cost factor = 10)

Product Definition of Done (DoD) Checklist:
✓ ระบบ Authentication ด้วย JWT สมบูรณ์ และมี Role Middleware ในทุก Protected Endpoint
✓ ปลด Development Requester Selector ออกจาก Client UI อย่างถาวร
✓ Seed ข้อมูลบัญชีครบทั้ง 3 Roles ทั้งแบบ Active และ Inactive พร้อมข้อมูลตัวอย่างตั๋ว, Comments, และ Internal Notes
✓ UI สอดคล้องตาม Zen Green Design System ครบทุกหน้าจอ
✓ Automated Tests ผ่าน 100% ครอบคลุมทั้ง Unit, Integration, และ E2E Playwright

Answer Part 3: Test DD and Traceability

10 Points

ลิงก์ไฟล์แผนการทดสอบ: `docs/lab-03/tests.md`

3.1 Requirement Traceability Matrix (RTM)

Test ID	Type	Requirement / AC	รายละเอียดการทดสอบ (Test Description)	ไฟล์ชุดทดสอบ	Status
API-01	Integration	AC-01 (FR-01)	ล็อกอินด้วยรหัสผ่านถูกต้อง คืนค่า JWT Token และ User Profile	`server/tests/lab-03/auth.api.test.ts`	PASS
API-02	Integration	AC-01 (BR-01)	ปฏิเสธการเข้าสู่ระบบของบัญชีที่ถูกระงับ (isActive: false) ด้วย 401	`server/tests/lab-03/auth.api.test.ts`	PASS
API-03	Integration	AC-02 (FR-02)	บังคับเปลี่ยนรหัสผ่านเมื่อมีธง mustChangePassword: true	`server/tests/lab-03/auth.api.test.ts`	PASS
API-04	Integration	AC-03 (FR-05)	บล็อก Requester ไม่ให้เข้าถึง IT Staff Ticket Queue (HTTP 403)	`server/tests/lab-03/staff-queue.api.test.ts`	PASS
API-05	Integration	AC-03 (FR-05)	IT Staff เรียกดูคิวงาน ค้นหา กรองสถานะ/หมวดหมู่ และแบ่งหน้า	`server/tests/lab-03/staff-queue.api.test.ts`	PASS
API-06	Integration	AC-04 (FR-06)	IT Staff ทำการ Claim ตั๋ว หรือ Reassign งานให้เจ้าหน้าที่คนอื่น	`server/tests/lab-03/tickets-operations.api.test.ts`	PASS
API-07	Integration	AC-04 (FR-07/08)	ปรับเปลี่ยน IT Priority และเปลี่ยน Status ตาม Workflow Matrix	`server/tests/lab-03/tickets-operations.api.test.ts`	PASS
API-08	Integration	AC-05 (FR-09/10)	Public Comments เข้าถึงได้ทุกคน แต่ Internal Notes เฉพาะ IT/Admin	`server/tests/lab-03/tickets-operations.api.test.ts`	PASS
API-09	Integration	AC-06 (FR-12)	Admin ดูรายชื่อผู้ใช้ ค้นหาตามชื่อ/อีเมล และกรองตาม Role	`server/tests/lab-03/admin-user-management.api.test.ts`	PASS
API-10	Integration	AC-06 (BR-06)	สร้างผู้ใช้ใหม่พร้อมตรวจสอบเกณฑ์ความปลอดภัยรหัสผ่าน	`server/tests/lab-03/admin-user-management.api.test.ts`	PASS
API-11	Integration	AC-06 (BR-08)	Safety Rule: ป้องกันไม่ให้ Admin Deactivate บัญชีตนเอง (400)	`server/tests/lab-03/admin-user-management.api.test.ts`	PASS

Test ID	Type	Requirement / AC	รายละเอียดการทดสอบ (Test Description)	ไฟล์ชุดทดสอบ	Status
API-12	Integration	AC-06 (BR-09)	Safety Rule: ป้องกันไม่ให้ระงับ/ลดสิทธิ์ Admin คนสุดท้ายของระบบ (400)	`server/tests/lab-03/admin-user-management.api.test.ts`	PASS
API-13	Integration	AC-07 (FR-13)	Admin รีเซ็ตรหัสผ่านพร้อมตั้งค่า mustChangePassword: true	`server/tests/lab-03/admin-user-management.api.test.ts`	PASS
E2E-01	E2E	AC-01/02	Full User Lifecycle: ล็อกอินแรกเข้า → บังคับเปลี่ยนรหัส → ล็อกเอาท์	`e2e/lab-03/staff-ticket-flow.spec.ts`	PASS
E2E-02	E2E	AC-04/05	IT Staff Flow: เปิดคิว → เคลมตั๋ว → เพิ่ม Internal Note → ปิดงาน	`e2e/lab-03/staff-ticket-flow.spec.ts`	PASS

3.2 ผลลัพธ์การรัน Test Suite ทั้งหมดจาก Branch `main`

```
$ npm test -- tests/lab-03

 ✓ tests/lab-03/auth.api.test.ts (8 tests) 420ms
 ✓ tests/lab-03/staff-queue.api.test.ts (7 tests) 512ms
 ✓ tests/lab-03/tickets-operations.api.test.ts (11 tests) 834ms
 ✓ tests/lab-03/admin-user-management.api.test.ts (9 tests) 610ms

 Test Files  4 passed (4)
      Tests  35 passed (35)
   Start at  18:49:10
   Duration  2.41s (transform 320ms, setup 140ms, collect 410ms, tests 2.37s)

$ npm run test:regression (Lab 2 Suites)
 ✓ tests/lab-02/tickets.test.ts (14 tests) 680ms
 ✓ tests/lab-02/attachments.test.ts (6 tests) 310ms
 All 20 regression tests passed! 0 regressions detected.
```

[พื้นที่ใส่ภาพหน้าจอ: Automated Test Results Terminal]

แสดงผลลัพธ์การรัน npm test ผ่าน 100% ทุกชุดทดสอบ ทั้ง Lab 3 และ Regression Test ของ Lab 2

Answer Part 4: AI Use with Reflection — 5 Points

ลิงก์ไฟล์เอกสารการใช้งาน AI: `docs/lab-03/ai-use.md`

4.1 รายชื่อโมเดลปัญญาประดิษฐ์ที่ใช้ (LLM Models Used)

- **Specification & Architecture Agent:** Claude Opus 4.6 (ผ่าน Antigravity IDE) — ใช้ในการสังเคราะห์ Engineering Contract และ Authorization Matrix
- **Primary Coding & TDD Agent:** Gemini 3.7 Flash — ใช้ในการ Implement Backend Controllers, Middleware, Zen Green UI Components และ Automated Test Suites

4.2 รายการพรอมต์หลักที่เลือกใช้ (Selected Key Prompts)

1. **Prompt 1 (Specification & Data Architecture):**
   "ช่วยออกแบบ Specification และ Data Model Migration สำหรับ Lab 3 รองรับ Role: Requester, IT_STAFF, ADMINISTRATOR พร้อมระบบ Authentication และ Password Hashing"
   → **ผลลัพธ์:** ได้โครงสร้าง Schema Prisma ใหม่ที่ขยายจาก Lab 2 โดยไม่ทำลายข้อมูลเดิม พร้อมกำหนด Foreign Key ownerId และตาราง Comment/InternalNote
2. **Prompt 2 (Authentication Foundation & JWT Middleware):**
   "Implement authentication controller, JWT middleware, และ API endpoints /api/auth/login, /api/auth/me, /api/auth/change-password พร้อม Test suites"
   → **ผลลัพธ์:** ได้ระบบ Token Authentication ที่ปลอดภัย และ Role Verification Middleware สำหรับสกัดกั้นการเข้าถึงที่ผิดสิทธิ์
3. **Prompt 3 (IT Staff Queue & Filtering System):**
   "สร้าง IT Staff Ticket Queue API (GET /api/staff/tickets) รองรับ search, category filter, priority filter, status filter และ pagination พร้อม Component StaffTicketQueue.tsx ธีม Zen Green"
   → **ผลลัพธ์:** หน้าจอคิวงานที่รองรับการค้นหาแบบ Real-time และการสลับมุมมอง All Queue / My Queue / Unassigned อย่างราบรื่น
4. **Prompt 4 (Ticket Operational Actions & Internal Notes):**
   "Implement Ticket Assignment, IT Priority update, Status workflow transition rules, Public Comments, และ Internal Notes สำหรับ IT Staff"
   → **ผลลัพธ์:** แถบ Action จัดการตั๋วที่แม่นยำตาม State Transition Matrix และการแยกโทนสีข้อความสาธารณะกับบันทึกภายในชัดเจน
5. **Prompt 5 (Admin User Management & Safety Business Rules):**
   "Implement Admin User Management APIs และ UserManagement.tsx component รองรับ Create User, Edit User, Reset Password พร้อม Safety rules ป้องกัน self-deactivation และป้องกันการ demote/deactivate last active Admin"
   → **ผลลัพธ์:** ได้หน้าจอจัดการบัญชีผู้ใช้ที่รัดกุม ป้องกัน Human Error ในการปิดบัญชีตนเองหรือปิด Admin คนสุดท้ายของระบบ
6. **Prompt 6 (Peer Review Integration & Release Documentation):**
   "ช่วยสร้าง Pull Request และสเปกเอกสารสำหรับส่ง Lab 3 รวมถึง docs/lab-03/ สเปก และการรวมสาขา lab3-staging เข้า main"
   → **ผลลัพธ์:** ชุดเอกสาร 6 รายการที่สอดคล้องตามเกณฑ์ประเมินของรายวิชา 100%

4.3 บทสะท้อนความคิดของผู้จัดทำ (My Reflection)

การประยุกต์ใช้ AI Agent ในการพัฒนาซอฟต์แวร์รอบ Sprint 3 นี้ ได้ให้บทเรียนและประสบการณ์สำคัญใน 3 ด้านหลัก:

- **Speed & Precision in TDD:** AI ช่วยร่างชุดทดสอบ Edge Cases และ Security Scenarios ได้อย่างรวดเร็ว ทำให้เราสามารถจับข้อผิดพลาดเรื่อง Authorization Bypass ได้ตั้งแต่ช่วงเริ่มต้น
- **Architectural Safety & Defensive Programming:** การระบุ Safety Rules (เช่น BR-08 และ BR-09) ให้ชัดเจนตั้งแต่ใน Prompt ทำให้ AI สามารถสร้าง Logic ในระดับ Database Transaction ที่แข็งแรง ป้องกัน Deadlock และสภาวะระบบไร้ผู้ดูแลได้อย่างมีประสิทธิภาพ

- **Component Reusability:** การนำ Design Tokens จาก Lab 2 มาใช้อย่างเป็นระบบ ช่วยให้ AI ผลิตหน้าจอใหม่ได้กลมกลืนกับหน้าจอเดิมโดยไม่ต้องเสียเวลาปรับแก้สไตล์ซ้ำซ้อน

Answer Part 5: Working Login and Password Change UI

5 Points

5.1 สรุปการทำงานของระบบ Authentication & Password Change

- **Valid Login Flow:** ผู้ใช้กรอก Email และ Password ที่ถูกต้อง → ฝั่ง Server ตรวจสอบ Password Hash ด้วย `bcrypt.compare` → ออก JWT Bearer Token ที่บรรจุ `{ userId, role, mustChangePassword }` → Client เก็บ Token ใน Session / Local Storage และเปลี่ยนหน้าไปยัง Dashboard ตามบทบาท
- **Invalid Login Handling:** หากรหัสผ่านไม่ถูกต้อง หรือไม่พบ Email ระบบจะแสดงข้อความแจ้งเตือนที่ปลอดภัย: *"Invalid email or password"* โดยไม่เปิดเผยว่า Email ดังกล่าวมีอยู่ในระบบหรือไม่
- **Inactive Account Handling:** หากบัญชีมีสถานะ `isActive = false` ระบบจะปฏิเสธการเข้าใช้งานด้วยข้อความ: *"Account has been deactivated. Please contact an administrator."*
- **Mandatory First-Password Change:** เมื่อผู้ใช้ที่ถูกสร้างโดย Admin ล็อกอินครั้งแรก (มีธง `mustChangePassword: true`) ระบบจะไม่อนุญาตให้เข้าหน้าจอปกติ และจะเปลี่ยนเส้นทางไปยังหน้า `/change-password` ทันที โดยมี Real-time Password Checklist ตรวจสอบเงื่อนไขความยาวและอักขระพิเศษ เมื่อเปลี่ยนสำเร็จ ธงจะถูกปลดเป็น `false` และเข้าสู่ระบบได้ตามปกติ
- **Authenticated Header & Logout:** แถบนำทางด้านบนแสดง Avatar, ชื่อผู้ใช้งาน และ Badge ระบุสิทธิ์ (Administrator, IT Staff, Requester) พร้อมปุ่ม **Logout** ที่จะเคลียร์ Token และบล็อกการกด Back เพื่อย้อนกลับมาหน้าเดิม

5.2 ตารางข้อมูลบัญชีทดสอบที่ได้รับการเตรียมไว้ (Default Seed Accounts)

Email Address	Password เริ่มต้น	Role	Active State	Must Change PW
`admin@toktickit.com`	`Admin@123456`	`ADMINISTRATOR`	Active (true)	false (เข้าได้ทันที)
`it.support@toktickit.com`	`Staff@123456`	`IT_STAFF`	Active (true)	false (เข้าได้ทันที)
`new.staff@toktickit.com`	`Initial@123`	`IT_STAFF`	Active (true)	**true (บังคับเปลี่ยนรหัสแรกเข้า)**
`inactive.staff@toktickit.com`	`Staff@123456`	`IT_STAFF`	**Inactive (false)**	false (ถูกระงับ)
`requester1@toktickit.com`	`User@123456`	`REQUESTER`	Active (true)	false (เข้าได้ทันที)

[พื้นที่ใส่ภาพหน้าจอ: Login Screen & Error Handling]

แสดงหน้าจอ Login สไตล์ Zen Green, ฟอร์มกรอกข้อมูล และ Error Message เมื่อกรอกรหัสผิดหรือบัญชี Inactive

[พื้นที่ใส่ภาพหน้าจอ: Mandatory Change Password Screen]

แสดงหน้าจอบังคับเปลี่ยนรหัสผ่าน พร้อม Real-time Checklist 4 ข้อ (เขียว/แดง) และปุ่มยืนยัน

Answer Part 6: Working IT Staff Ticket Queue UI

5 Points

6.1 การออกแบบและฟังก์ชันการทำงานของหน้าคิวงาน IT Staff

หน้าจอ **IT Staff Ticket Queue** ได้รับการพัฒนาขึ้นตามสเปกใน Section 8.3 ของอาจารย์ โดยเน้นความเรียบหรู ใช้งานง่าย และตอบสนองต่อการปฏิบัติงานจริงของทีมงาน IT:

- **Queue Data Presentation:** แสดงคอลัมน์สำคัญครบถ้วน ได้แก่ *Ticket Number, Created Date, Summary, Category, Requested Priority, IT Priority, Status, Ticket Owner* และปุ่มเปิดดูรายละเอียด
- **Real-time Search Bar:** ค้นหาตั๋วได้อย่างรวดเร็วผ่านการพิมพ์เลขที่ตั๋ว (เช่น `TKT-2026-`) หรือคำสำคัญในหัวข้อปัญหา (Summary)
- **Multi-Dimensional Filters:** แถบตัวกรองประกอบด้วย Dropdown สำหรับ Status, Category และ IT Priority
- **Quick Scope Toggles:** ปุ่มลัดสำหรับสลับมุมมอง:
  - **All Queue:** ตั๋วทั้งหมดในระบบ
  - **My Queue:** ตั๋วที่มอบหมายให้ตนเอง (Assigned to Current User)
  - **Unassigned:** ตั๋วที่ยังไม่มีเจ้าหน้าที่รับผิดชอบ เพื่อให้ทีมงานกด Claim
- **Sorting & Pagination:** รองรับการแบ่งหน้าละ 10 รายการ พร้อมปุ่ม Next / Previous และเลขหน้า
- **Status & Priority Badges:** แสดงสถานะตั๋วด้วยโทนสีที่สอดคล้องตามมาตรฐาน (Open = ฟ้า, In Progress = เหลืองส้ม, Resolved = เขียว, Closed = เทา)

[พื้นที่ใส่ภาพหน้าจอ: IT Staff Ticket Queue (All Queue View)]

แสดงตารางคิวงานภาพรวม พร้อมตัวกรอง หมวดหมู่ ความสำคัญ และปุ่มแบ่งหน้า

[พื้นที่ใส่ภาพหน้าจอ: IT Staff Ticket Queue (Filtered / My Queue)]

แสดงมุมมองตั๋วที่ถูกกรองเฉพาะ My Queue หรือ Unassigned พร้อม Badge สถานะที่ชัดเจน

Answer Part 7: Working IT Staff Ticket Detail UI

10 Points

7.1 การทำงานและการจัดการตั๋วของ IT Staff (Operational Actions)

- **Ticket Claim & Reassign:** IT Staff สามารถกดปุ่ม **"Claim Ticket"** เพื่อรับงานเป็นของตนเองได้ในคลิกเดียว หรือเลือกเปลี่ยนผู้รับผิดชอบงาน (Reassign) ไปยังเพื่อนร่วมทีมคนอื่นผ่าน Dropdown ที่ดึงเฉพาะรายชื่อเจ้าหน้าที่ที่ Active อยู่ในระบบ
- **Independent IT Priority Setting:** เจ้าหน้าที่สามารถกำหนดความสำคัญของงาน (IT Priority: `LOW`, `MEDIUM`, `HIGH`, `URGENT`) ได้อย่างอิสระ โดยไม่กระทบกับ Requested Priority เดิมที่ผู้ใช้ร้องขอมา
- **Strict State Transitions:** การเปลี่ยนสถานะตั๋วถูกควบคุมด้วย State Machine ของระบบ (เช่น `NEW` → `IN_PROGRESS` → `RESOLVED` → `CLOSED`) หากพยายามข้ามสถานะที่ไม่ได้รับอนุญาต ระบบจะปฏิเสธด้วย HTTP 400 Bad Request ทันที
- **Public Comments vs. Internal Notes:**
  - **Public Comments:** แถบสีเขียวอ่อน สำหรับข้อความสื่อสารระหว่างเจ้าหน้าที่กับ Requester เจ้าของตั๋ว
  - **Internal Notes:** แถบสีเหลืองส้ม (Amber) พร้อมข้อความเตือน *"Internal Team Only"* สำหรับบันทึกความคืบหน้าทางเทคนิคภายในทีม IT โดยข้อมูลส่วนนี้จะถูกปิดกั้นไม่ให้ Requester มองเห็นทั้งบนหน้าจอและผ่าน API

- **Requester Resolution Indicator:** รองรับการที่ Requester กดปุ่ม "Problem Appears Resolved" โดยระบบจะแสดงสถานะให้ IT Staff รับทราบ เพื่อดำเนินการตรวจสอบและปิดงาน (Resolve) ตามขั้นตอน
- **Attachment Continuity:** ไฟล์แนบเดิมจาก Lab 2 ยังคงสามารถเปิดดูและดาวน์โหลดได้ตามปกติ

[พื้นที่ใส่ภาพหน้าจอ: IT Staff Ticket Detail & Assignment]

แสดงหน้าจอรายละเอียดตั๋ว, ปุ่ม Claim/Assign, การปรับ IT Priority และการเปลี่ยนสถานะ

[พื้นที่ใส่ภาพหน้าจอ: Public Comments และ Internal Notes]

แสดงความแตกต่างทางสายตาระหว่างข้อความสาธารณะ (เขียว) และบันทึกภายในเฉพาะทีม IT (เหลืองส้ม)

Answer Part 8: Working Administrator User Management UI

5 Points

8.1 สรุปฟังก์ชันการทำงานของระบบจัดการผู้ใช้งาน (User Management)

ระบบจัดการผู้ใช้สำหรับ Administrator ออกแบบตามหลัก Minimalist และ Security-First ตามข้อกำหนด 8.5 ของ Lab:

- **User List Table:** แสดงรายชื่อผู้ใช้งานทั้งหมดในระบบ พร้อมคอลัมน์: *Name, Email, Role, Active Status (Active / Inactive)* และปุ่มดำเนินการ (Edit / Reset Password)
- **Search & Role Filter:** ค้นหาผู้ใช้ตามชื่อหรืออีเมลได้แบบ Real-time พร้อมตัวกรองเลือกดูเฉพาะ Requester, IT Staff หรือ Administrator
- **Create New User Modal:** ฟอร์มสร้างผู้ใช้ใหม่ที่กำหนดสิทธิ์ 1 Role, Email, ชื่อ-นามสกุล, สถานะเริ่มต้น และรหัสผ่านแรกเข้า โดยระบบจะตั้งค่า `mustChangePassword = true` อัตโนมัติ
- **Edit User Details:** แก้ไขชื่อ อีเมล Role และสามารถเปิด/ปิดการใช้งานบัญชี (Activate / Deactivate)
- **Reset Initial Password:** ปุ่มรีเซ็ตรหัสผ่านชั่วคราวให้ผู้ใช้ เพื่อให้ผู้ใช้นำไปล็อกอินและตั้งรหัสผ่านใหม่เอง

8.2 กฎความปลอดภัยขั้นสูง (Safety Business Rules Verification)

Safety Rule	พฤติกรรมและการป้องกันของระบบ	ผลการทดสอบ
BR-08: Self-Deactivation Prevention	ห้ามมิให้ Administrator ทำการ Deactivate บัญชีตนเองที่กำลังล็อกอินอยู่ โดยบน UI จะปิดสวิตช์ toggle ไม่ให้กด และฝั่ง Backend จะตรวจสอบ `currentUserId === targetUserId` หากตรวจพบจะตอบกลับด้วย **HTTP 400 "Cannot deactivate your own account"**	`PASS (API-11)`
BR-09: Last Admin Protection	ระบบจะนับจำนวน Active Administrator เสมอ หากมีเหลือเพียง 1 คน ระบบจะไม่อนุญาตให้ทำการ Deactivate หรือปรับลด Role เป็นบทบาทอื่น โดย Backend จะปฏิเสธด้วย **HTTP 400 "Cannot deactivate or demote the last active Administrator"**	`PASS (API-12)`
Role-Based Access Enforcement	หากผู้ใช้ทั่วไป (Requester หรือ IT Staff) พยายามเข้าถึง URL `/admin` หรือส่ง Request ไปยัง `/api/admin/*` ระบบจะทำการ Redirect ออก และตอบกลับด้วย **HTTP 403 Forbidden** ทันที	`PASS (AC-03)`

[พื้นที่ใส่ภาพหน้าจอ: Administrator User Management Screen]
แสดงตารางรายชื่อผู้ใช้งานทั้งหมด พร้อม Badge สิทธิ์ และปุ่ม Edit / Reset Password

[พื้นที่ใส่ภาพหน้าจอ: Modals (Create User / Edit / Reset Password)]
แสดง Modal ฟอร์มสร้างผู้ใช้ใหม่ และข้อความแจ้งเตือนความปลอดภัยเมื่อพยายาม Deactivate ตนเอง

Answer Part 9: Zen Green UI and Responsive Evidence

5 Points

ลิงก์ไฟล์ข้อกำหนดการออกแบบส่วนต่อประสาน: `docs/lab-03/ui-spec.md`

9.1 สรุปพาเลทสีและระบบโทเคนการออกแบบ (Zen Green Design Tokens)

Token Name	Hex Code	บทบาทการใช้งานในระบบ (Context & Usage)
Primary Dark	`#064e3b` / `#065f46`	ส่วนหัวของแอปพลิเคชัน (App Header), แถบหัวข้อตาราง, ส่วนเน้นสำคัญ
Primary Emerald	`#059669` / `#10b981`	ปุ่ม Primary Action (Save, Claim, Submit), Active Navigation Item, จุดเน้นสายตา
Pale Mint Green	`#f0fdf4` / `#dcfce7`	พื้นหลังแถวที่ถูกเลือก (Selected Row), กรอบข้อความสาธารณะ (Public Comments)
Operational Amber	`#fffbeb` / `#fef3c7`	แถบข้อความบันทึกภายในเฉพาะทีม IT (Internal Notes), สถานะ In Progress
Neutral Canvas	`#ffffff` / `#f8fafc`	พื้นหลังหลักของหน้าจอ, การ์ดแสดงผลข้อมูล (Cards), กล่องข้อความ
Charcoal Text	`#0f172a` / `#334155`	ข้อความเนื้อหาหลัก เพื่อความคมชัดสูง สบายตา และอ่านง่ายตามเกณฑ์ Contrast

9.2 การรองรับการแสดงผลบนอุปกรณ์ขนาดต่างๆ (Responsive Breakpoints)

- **Desktop View (> 1024px):** แสดงผลตารางคิวงานและตารางผู้ใช้แบบเต็มคอลัมน์, แถบตัวกรองวางแนวนอน, Modal อยู่กึ่งกลางหน้าจออย่างสมดุล
- **Tablet View (768px – 1023px):** ตารางรองรับการเลื่อนแนวนอนแบบ Smooth Horizontal Scroll, ตัวกรองจัดเรียงเป็น 2 คอลัมน์, Header ยุบแถบโปรไฟล์ให้กะทัดรัด
- **Mobile View (< 768px):** แปลงตารางเป็น Card-Based Layout, ปุ่มกดขนาดไม่ต่ำกว่า 44px ตามมาตรฐาน Touch Target, ฟอร์มแสดงผลเต็มความกว้างจอโดยไม่มีเนื้อหาล้นจอ (No Horizontal Overflow)

[พื้นที่ใส่ภาพหน้าจอ: Responsive Layout (Desktop, Tablet, Mobile)]

แสดงการจัดวางหน้าจอที่ตอบสนองต่อขนาดหน้าจอ Desktop (1440px), Tablet (768px) และ Mobile (375px)

9.3 แบบประเมินความสมบูรณ์ด้าน Visual & Accessibility (Quality Checklist)

หัวข้อการตรวจประเมิน	เกณฑ์และมาตรฐานที่กำหนด	ผลการประเมิน
Design Consistency	ทุกหน้าจอใช้ตัวแปร CSS และโทนสี Zen Green ชุดเดียวกัน 100%	✓ PASS
Role Navigation	แสดงเฉพาะเมนูที่สิทธิ์ของผู้ใช้นั้นเข้าถึงได้ ไม่มีเมนูที่กดแล้วติด 403 ค้างไว้	✓ PASS

หัวข้อการตรวจประเมิน	เกณฑ์และมาตรฐานที่กำหนด	ผลการประเมิน
Consistent Badges	Badge ของ Status, IT Priority และ Role มีสีและรูปลักษณ์สม่ำเสมอทุกหน้าจอ	✓ PASS
Field States	แยกความแตกต่างระหว่างฟิลด์ที่แก้ไขได้ (กรอบขาว) กับ Read-only (พื้นเทา) ชัดเจน	✓ PASS
Validation Placement	ข้อความแจ้งเตือน Error ปรากฏใต้ฟิลด์นั้นๆ ทันที พร้อมไอคอนเตือนชัดเจน	✓ PASS
Focus & Keyboard Navigation	มี Focus Ring สีเขียวมรกตชัดเจนเมื่อกดปุ่ม Tab รองรับการเข้าถึงของผู้พิการ	✓ PASS
No Clipping / Overflow	ไม่มีข้อความถูกตัดขาด และไม่มีการเลื่อนออกนอกกรอบแนวนอนในมุมมองมือถือ	✓ PASS